AUDITORIA AVANÇADA

Relatório de Auditoria de Segurança Avançada — TaskFlow

30/10/2026 · Projeto: TaskFlow

EXEMPLO FICTÍCIO

Este é um RELATÓRIO DE EXEMPLO. O projeto TaskFlow, os arquivos, as linhas e os achados são fictícios e servem apenas para mostrar o formato do resultado.

Stack detectada

Next.js 14.1.0 (App Router, middleware) · TypeScript · Supabase (Postgres + RLS, Auth, Storage) · Stripe (checkout + webhooks) · OpenAI API (resumo de tarefas) · Vercel · Docker Compose (dev) · GitHub Actions

Escopo auditado

Repositório completo (612 arquivos analisados), 36 rotas de API, 4 server actions, 2 webhooks, 1 cron job, 20 migrations, 3 workflows de CI, docker-compose.yml, bundle de produção e histórico Git (447 commits).

Nota metodológica

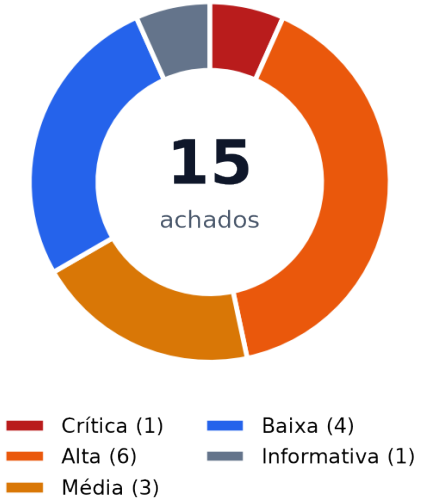
Item	Como foi analisado
Referência	OWASP Top 10:2025 + TTPs de ataque web + OWASP Top 10 for LLM Applications.
Mapeamento	Matrizes de endpoints (36), recursos (11) e modelo de identidade construídas antes da análise.
Evidência	Cada achado tem fluxo source -> sink demonstrado no código e passou pelo filtro de falsos positivos.
Ferramentas	npm audit, gitleaks (já instalado) e revisão manual. Nenhum teste dinâmico ou ataque real foi executado.

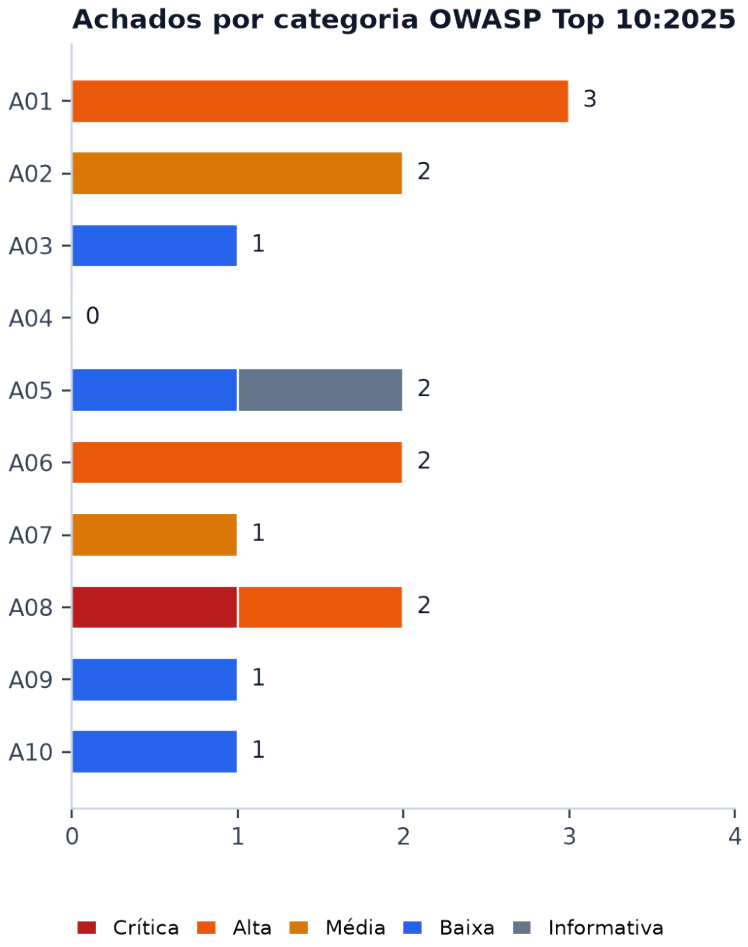
Limitações

Configurações feitas apenas no painel do Supabase e da Vercel (ex: policies de Storage criadas pela interface, headers de borda) não estão no repositório e não puderam ser verificadas.

Resumo executivo

1	6	3	4	1	8
CRÍTICA	ALTA	MÉDIA	BAIXA	INFORMATIVA	PONTOS FORTES





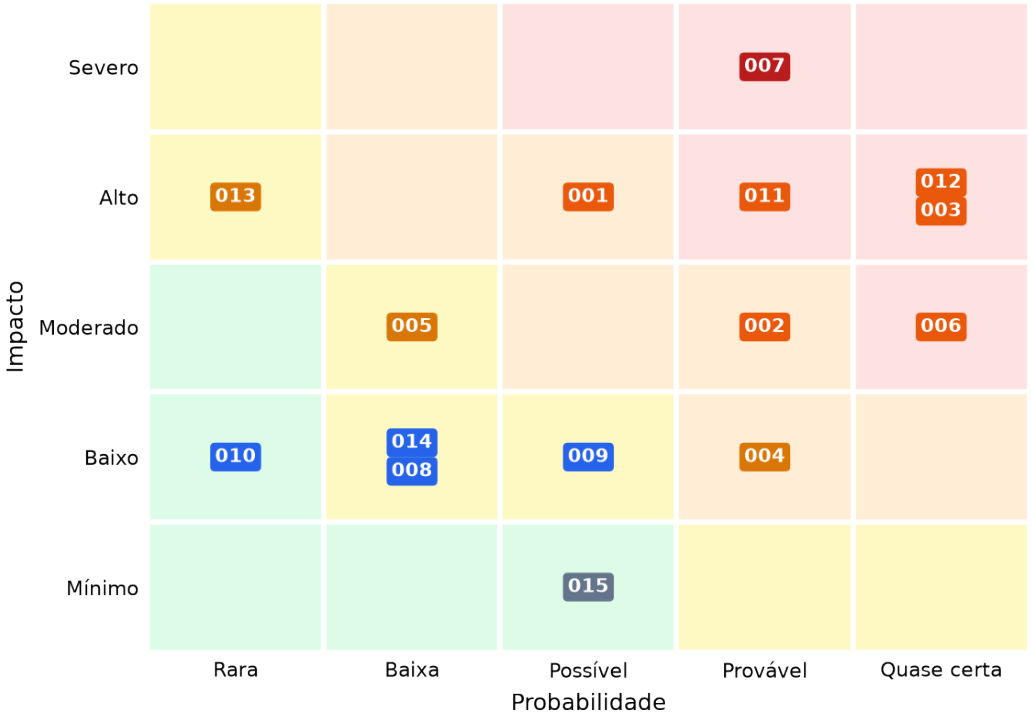
Evolução desde a auditoria básica

5 corrigidos · **4** persistentes · **11** achados novos nesta auditoria

ID	Achado da básica	Status	Evidência
B-01	Tabela invoices sem RLS	CORRIGIDO	Migration 20261015_invoices_rls.sql habilita RLS com policies por org_id.
B-02	Policy de tasks com USING (true)	PERSISTENTE	Virou SEC-012.
B-03	DELETE de usuário sem checagem de admin	PERSISTENTE	Virou SEC-011.
B-04	IDOR na exportação de projeto	CORRIGIDO	export/route.ts:14 agora valida membership antes da consulta.
B-05	Service role key no bundle	CORRIGIDO	Renomeada sem NEXT_PUBLIC_; admin.ts importa 'server-only'; bundle limpo.
B-06	Chave do Stripe no histórico Git	CORRIGIDO	Chave antiga ainda no histórico, mas revogada (informado pela equipe; confirmar no painel).
B-07	JWT_SECRET com default 'changeme'	PERSISTENTE	Virou SEC-013.
B-08	XSS nos comentários	CORRIGIDO	TaskComment.tsx:22 usa DOMPurify.sanitize.
B-09	HTML sem escape no e-mail de convite	PERSISTENTE	Virou SEC-014.

Mapa de risco

Impacto × probabilidade. Cada marcador é um achado (número do SEC), colorido pela severidade.



Pontos fortes

Controles encontrados e verificados no código, com evidência.

Controle	Evidência
Correções da auditoria básica verificadas	B-01, B-04, B-05 e B-08 corrigidos com evidência (ver Evolução).
RLS completo nas tabelas principais	projects, members, files, invoices e comments: policies por org_id nas 4 operações (migrations 20250301 e 20261015).
SQL sempre parametrizado	Nenhuma query concatenada; as 3 consultas raw em lib/reports/ usam parâmetros ($1, $2).
Upload valida tipo e tamanho	app/api/files/route.ts:20-41 valida magic bytes, limita a 10 MB e grava com nome aleatório em bucket privado.
Server actions verificam sessão e membership	As 4 actions em app/(app)/actions.ts chamam requireMember(orgId) na primeira linha.
Cookies de sessão seguros	Supabase Auth com HttpOnly e Secure; nenhum token em localStorage.
Open redirect bloqueado	app/auth/callback/route.ts:9 aceita apenas caminhos relativos iniciados por '/' e rejeita '//'.
Nenhum segredo no bundle atual	Varredura de .next/static e source maps (desativados em produção) sem chaves.

Pontos fracos

- CI/CD permite que PRs de forks acessem secrets de produção (SEC-007).
- Integrações externas confiam em dados sem verificar origem: webhook do Stripe e teste de URL (SEC-003, SEC-001).
- Achados de autorização da auditoria básica ainda abertos (SEC-011, SEC-012).
- Lógica de cobrança sem operações atômicas e com fail-open (SEC-002, SEC-008).
- Endpoint de IA aberto ao público, sem controle de custo (SEC-006).

Matriz OWASP Top 10:2025

OWASP	Categoria	Status	Achados	Observação
A01	Broken Access Control	VERIFICADO	**3**	SSRF + 2 persistentes da básica
A02	Security Misconfiguration	VERIFICADO	**2**	CORS e default de segredo
A03	Software Supply Chain Failures	VERIFICADO	**1**	npm audit: 4 alertas, 1 aplicável
A04	Cryptographic Failures	VERIFICADO	**0**	Hash de senha e tokens pelo Supabase Auth
A05	Injection	VERIFICADO	**2**	SQL parametrizado; XSS só em e-mail
A06	Insecure Design	VERIFICADO	**2**	Race condition e custo de IA
A07	Authentication Failures	VERIFICADO	**1**	Reset de senha
A08	Software or Data Integrity Failures	VERIFICADO	**2**	CI e webhook
A09	Security Logging and Alerting Failures	VERIFICADO	**1**	Sem audit log admin
A10	Mishandling of Exceptional Conditions	VERIFICADO	**1**	Fail-open em limites

Matriz de TTPs

TTP	Aplicável	Verificado	Achados
Reconhecimento	Sim	Sim	**1**
Credential Attacks	Sim	Sim	**2**
Session Attacks	Sim	Sim	**0**
Authorization Abuse	Sim	Sim	**2**
XSS	Sim	Sim	**1**
CSRF	Sim	Sim	**0**
CORS Abuse	Sim	Sim	**1**
Open Redirect	Sim	Sim	**0**
File Upload	Sim	Sim	**0**
Path Traversal	Sim	Sim	**0**
Deserialization	Não	N/A	**0**
Prototype Pollution	Sim	Sim	**0**
HTTP Request Smuggling	Sim	Não confirmado	**0**
HTTP Parameter Pollution	Sim	Sim	**0**
Race Conditions	Sim	Sim	**1**
Business Logic Abuse	Sim	Sim	**2**
SSRF	Sim	Sim	**1**
Supply Chain	Sim	Sim	**2**
LLM / Prompt Injection	Sim	Sim	**2**

Cobertura

Item	Total	Analisados	Não aplicáveis	Não confirmados
Endpoints e handlers	43	43	0	0
Recursos (entidades)	11	11	0	0
Workflows de CI	3	3	0	0
Migrations	20	20	0	0

Achados detalhados

ID	Severidade	OWASP	TTP	Arquivo:linha	Descrição
SEC-007	CRÍTICA	A08	Supply Chain	`.github/workflows/preview.yml:3-24`	pull_request_target executa código de forks com acesso a secrets
SEC-003	ALTA	A08	Business Logic Abuse	`app/api/webhooks/stripe/route.ts:9-21`	Webhook do Stripe aceito sem verificar assinatura
SEC-001	ALTA	A01	SSRF	`app/api/integrations/test/route.ts:11-19`	SSRF no teste de webhook de integração
SEC-002	ALTA	A06	Race Conditions	`lib/billing/coupons.ts:31-44`	Cupom de uso único pode ser usado várias vezes (race condition)
SEC-006	ALTA	A06	LLM / Prompt Injection	`app/api/ai/summarize/route.ts:6-18`	Endpoint de IA sem autenticação e sem limite de uso
SEC-011	ALTA	A01	Authorization Abuse	`app/api/admin/users/[id]/route.ts:8-20`	DELETE de usuário sem verificação de admin (B-03)
SEC-012	ALTA	A01	Authorization Abuse	`supabase/migrations/20250402_tasks_policies.sql:8-10`	Policy de tasks com USING (true) (B-02)
SEC-004	MÉDIA	A07	Credential Attacks	`app/api/auth/reset/route.ts:7-16`	Reset de senha sem rate limit e com enumeração de e-mails
SEC-005	MÉDIA	A02	CORS Abuse	`middleware.ts:18-23`	CORS reflete qualquer origem com credenciais
SEC-013	MÉDIA	A02	Credential Attacks	`docker-compose.yml:22`	JWT_SECRET com default 'changeme' (B-07)
SEC-008	BAIXA	A10	Business Logic Abuse	`lib/billing/limits.ts:22-30`	Checagem de limite do plano falha aberta (fail-open)
SEC-009	BAIXA	A09	Reconhecimento	`app/api/admin/ (8 handlers)`	Ações administrativas sem registro de auditoria
SEC-010	BAIXA	A03	Supply Chain	`package.json:18`	Next.js 14.1.0 vulnerável a bypass de middleware (CVE-2025-29927), impacto mitigado
SEC-014	BAIXA	A05	XSS	`lib/email/invite.ts:14`	HTML sem escape no e-mail de convite (B-09)
SEC-015	INFORMATIVA	A05	LLM / Prompt Injection	`app/api/ai/summarize/route.ts:12`	Prompt injection possível, sem sink de impacto

Detalhamento dos achados

CRÍTICA **SEC-007 pull_request_target executa código de forks com acesso a secrets**

Status: NOVO · **Prioridade:** P1 · **Confiança:** CONFIRMADO · **OWASP:** A08:2025 · **CWE-829** · **TTP:** Supply Chain

Arquivo	`.github/workflows/preview.yml:3-24`

Evidência	`on: pull_request_target`
	`...`
	`- uses: actions/checkout@v4`
	`  with:`
	`  ref: ${{ github.event.pull_request.head.sha }}`
	`- run: npm ci && npm run build`
	`  env:`
	`  VERCEL_TOKEN: ${{ secrets.VERCEL_TOKEN }}`

Source	Pull request de qualquer fork (package.json e scripts controlados pelo autor do PR)
Sink	npm ci / npm run build com VERCEL_TOKEN e SUPABASE_SERVICE_ROLE_KEY no ambiente
Exploração	O atacante abre um PR alterando o script postinstall para enviar as variáveis de ambiente para um servidor dele. O workflow roda o código do PR com os secrets do repositório.
Pré-condições	Repositório público (confirmado) e workflow habilitado para forks.
Impacto	Roubo do token de deploy da Vercel e da service role key: comprometimento total da produção.
Correção	Trocar para on: pull_request (sem secrets) ou separar build (sem secrets) e deploy (com secrets) em workflows distintos; restringir permissions: e pinar actions por SHA.

ALTA **SEC-001 SSRF no teste de webhook de integração**

Status: NOVO · **Prioridade:** P1 · **Confiança:** CONFIRMADO · **OWASP:** A01:2025 · **CWE-918** · **TTP:** SSRF

Arquivo	`app/api/integrations/test/route.ts:11-19`

Evidência	`const { url } = await req.json();`
	`const res = await fetch(url, { method: 'POST', body: sample });`
	`return Response.json({ status: res.status, body: await res.text() });`

Source	body.url (usuário autenticado, qualquer plano)
Sink	fetch() no servidor, com a resposta devolvida ao usuário
Exploração	O usuário informa http://169.254.169.254/... ou um serviço interno e recebe a resposta completa.
Pré-condições	Conta gratuita. Impacto depende da rede do ambiente de execução.
Impacto	Leitura de serviços internos e de metadata de cloud.
Correção	Permitir apenas https, resolver o DNS e bloquear IPs privados, loopback e link-local (inclusive após redirects); não devolver o corpo da resposta.

ALTA SEC-002 Cupom de uso único pode ser usado várias vezes (race condition)

Status: NOVO · **Prioridade:** P2 · **Confiança:** CONFIRMADO · **OWASP:** A06:2025 · **CWE-362** · **TTP:** Race Conditions

Arquivo	`lib/billing/coupons.ts:31-44`

Evidência	`const coupon = await getCoupon(code);`
	`if (coupon.used_count < coupon.max_uses) {`
	`  await applyCredit(orgId, coupon.credit_cents);`
	`  await incrementUse(coupon.id);`
	`}`

Source	POST /api/billing/redeem com o mesmo código
Sink	applyCredit() adiciona saldo
Exploração	Enviar 20 requisições simultâneas com o mesmo cupom: todas passam pela checagem antes do incremento.
Pré-condições	Possuir um código de cupom válido.
Impacto	Créditos ilimitados a partir de um cupom único.
Correção	Fazer o incremento atômico: update coupons set used_count = used_count + 1 where id = $1 and used_count < max_uses returning *, dentro de uma transação.

ALTA SEC-003 Webhook do Stripe aceito sem verificar assinatura

Status: NOVO · **Prioridade:** P1 · **Confiança:** CONFIRMADO · **OWASP:** A08:2025 · **CWE-345** · **TTP:** Business Logic Abuse

Arquivo	`app/api/webhooks/stripe/route.ts:9-21`

Evidência	`export async function POST(req: Request) {`
	`  const event = await req.json();`
	`  if (event.type === 'checkout.session.completed') {`
	`  await activatePlan(event.data.object.metadata.org_id, 'pro');`

Source	Corpo da requisição POST /api/webhooks/stripe
Sink	activatePlan() altera o plano da organização
Exploração	Qualquer pessoa envia um JSON imitando o evento checkout.session.completed com o org_id dela e ganha o plano Pro sem pagar.
Pré-condições	Nenhuma: endpoint público.
Impacto	Fraude de assinatura e perda de receita.
Correção	Usar stripe.webhooks.constructEvent(rawBody, sig, STRIPE_WEBHOOK_SECRET) e rejeitar com 400 se falhar.

ALTA SEC-006 Endpoint de IA sem autenticação e sem limite de uso

Status: NOVO · **Prioridade:** P2 · **Confiança:** CONFIRMADO · **OWASP:** A06:2025 · **CWE-770** · **TTP:** LLM / Prompt Injection

Arquivo	`app/api/ai/summarize/route.ts:6-18`

Evidência	`export async function POST(req: Request) {`
	`  const { text } = await req.json();`
	`  const r = await openai.chat.completions.create({`
	`  model: 'gpt-4.1', messages: [{ role: 'user', content: text }] });`

Source	body.text de qualquer visitante, sem limite de tamanho
Sink	Chamada paga à API da OpenAI
Exploração	Um script chama o endpoint em loop com textos grandes e usa a conta da empresa como proxy gratuito de LLM.
Pré-condições	Nenhuma: rota não exige sessão.
Impacto	Custo descontrolado (denial of wallet) e bloqueio da conta por limite de uso.
Correção	Exigir sessão, limitar tamanho do texto e aplicar rate limit e cota diária por organização.

ALTA SEC-011 DELETE de usuário sem verificação de admin (B-03)

Status: PERSISTENTE · **Prioridade:** P1 · **Confiança:** CONFIRMADO · **OWASP:** A01:2025 · **CWE-285** · **TTP:** Authorization Abuse

Arquivo	`app/api/admin/users/[id]/route.ts:8-20`

Evidência	`const user = await getSessionUser();`
	`if (!user) return new Response(null, { status: 401 });`
	`await supabaseAdmin.from('users').delete().eq('id', params.id);`

Source	params.id
Sink	delete em users com client service_role
Exploração	Usuário comum chama DELETE /api/admin/users/<id> diretamente.
Pré-condições	Estar logado.
Impacto	Remoção de qualquer conta.
Correção	Aplicar requireAdmin() e validar a organização do alvo.

ALTA SEC-012 Policy de tasks com USING (true) (B-02)

Status: PERSISTENTE · **Prioridade:** P1 · **Confiança:** CONFIRMADO · **OWASP:** A01:2025 · **CWE-639** · **TTP:** Authorization Abuse

Arquivo	`supabase/migrations/20250402_tasks_policies.sql:8-10`
Evidência	`create policy "tasks_select" on public.tasks` `  for select to authenticated using (true);`
Source	Requisição REST do Supabase com JWT de qualquer usuário
Sink	select em tasks
Exploração	GET /rest/v1/tasks?select=* com a sessão de uma conta gratuita.
Pré-condições	Ter uma conta.
Impacto	Leitura das tarefas de todas as organizações.
Correção	Filtrar por org_id via members.

MÉDIA SEC-004 Reset de senha sem rate limit e com enumeração de e-mails

Status: NOVO · **Prioridade:** P2 · **Confiança:** CONFIRMADO · **OWASP:** A07:2025 · **CWE-307** · **TTP:** Credential Attacks

Arquivo	`app/api/auth/reset/route.ts:7-16`
Evidência	`if (!user) return Response.json({ error: 'E-mail não cadastrado' }, { status: 404 });` `await sendResetEmail(user);`
Source	body.email
Sink	Resposta diferente para e-mail existente / envio de e-mail
Exploração	Descobrir quais e-mails são clientes e disparar milhares de e-mails de reset.
Pré-condições	Nenhuma.
Impacto	Lista de clientes para phishing; abuso do provedor de e-mail.
Correção	Resposta sempre igual (200) e rate limit por IP e por e-mail.

MÉDIA SEC-005 CORS reflete qualquer origem com credenciais

Status: NOVO · **Prioridade:** P2 · **Confiança:** PROVÁVEL · **OWASP:** A02:2025 · **CWE-942** · **TTP:** CORS Abuse

Arquivo	`middleware.ts:18-23`
Evidência	`res.headers.set('Access-Control-Allow-Origin', req.headers.get('origin') ?? '*');` `res.headers.set('Access-Control-Allow-Credentials', 'true');`
Source	Header Origin
Sink	Headers CORS da resposta
Exploração	Um site malicioso faz fetch com credentials: 'include' para a API e lê as respostas da vítima logada.
Pré-condições	Cookies de sessão com SameSite=None (padrão do domínio customizado, confirmar na Vercel).
Impacto	Leitura de dados da vítima a partir de outro site.
Correção	Usar allowlist fixa de origens (app.taskflow.com).

MÉDIA SEC-013 JWT_SECRET com default 'changeme' (B-07)

Status: PERSISTENTE · **Prioridade:** P3 · **Confiança:** CONFIRMADO · **OWASP:** A02:2025 · **CWE-1188** · **TTP:** Credential Attacks

Arquivo	`docker-compose.yml:22`
Evidência	`- JWT_SECRET=${JWT_SECRET:-changeme}`
Source	Ambiente sem JWT_SECRET
Sink	Assinatura de tokens
Exploração	Forjar tokens em ambientes sem a variável.
Pré-condições	Deploy via Docker sem a variável definida.
Impacto	Sessões forjadas.
Correção	Remover default e validar no startup.

BAIXA SEC-008 Checagem de limite do plano falha aberta (fail-open)

Status: NOVO · **Prioridade:** P3 · **Confiança:** CONFIRMADO · **OWASP:** A10:2025 · **CWE-636** · **TTP:** Business Logic Abuse

Arquivo	`lib/billing/limits.ts:22-30`
Evidência	`try { return (await countProjects(orgId)) < plan.maxProjects; } catch { return true; // não bloquear o usuário }`
Source	Erro no banco (timeout)
Sink	Criação de projeto
Exploração	Durante instabilidade do banco, o limite do plano gratuito é ignorado.
Pré-condições	Erro na consulta de contagem.
Impacto	Uso de recursos pagos sem pagar (impacto limitado).
Correção	Em caso de erro, negar (fail-closed) e registrar o evento.

BAIXA SEC-009 Ações administrativas sem registro de auditoria

Status: NOVO · **Prioridade:** P3 · **Confiança:** CONFIRMADO · **OWASP:** A09:2025 · **CWE-778** · **TTP:** Reconhecimento

Arquivo	`app/api/admin/ (8 handlers)`
Evidência	`// nenhuma chamada a audit log em app/api/admin/**/route.ts`
Source	Ações de administradores
Sink	Ausência de audit trail
Exploração	Não há como investigar quem removeu usuários ou alterou planos.
Pré-condições	Incidente ocorrido.
Impacto	Investigação e resposta a incidentes prejudicadas.
Correção	Criar tabela audit_logs (actor, ação, recurso, timestamp, IP) e registrar em toda rota admin.

BAIXA SEC-010 Next.js 14.1.0 vulnerável a bypass de middleware (CVE-2025-29927), impacto mitigado

Status: NOVO · **Prioridade:** P3 · **Confiança:** CONFIRMADO · **OWASP:** A03:2025 · **CWE-1104** · **TTP:** Supply Chain

Arquivo	`package.json:18`
Evidência	`"next": "14.1.0"`
Source	Header x-middleware-subrequest
Sink	Pular a execução do middleware.ts
Exploração	Versão vulnerável, mas o middleware só faz CORS e redirect; a autenticação é verificada em cada handler. Impacto real limitado.
Pré-condições	Hospedagem fora da Vercel (a Vercel bloqueia o header).
Impacto	Baixo hoje; vira alto se a autenticação for movida para o middleware.
Correção	Atualizar para next >= 14.2.25.

BAIXA SEC-014 HTML sem escape no e-mail de convite (B-09)

Status: PERSISTENTE · **Prioridade:** P3 · **Confiança:** CONFIRMADO · **OWASP:** A05:2025 · **CWE-79** · **TTP:** XSS

Arquivo	`lib/email/invite.ts:14`
Evidência	`html: ` ${inviterName} convidou você para o TaskFlow ``
Source	users.name
Sink	HTML do e-mail
Exploração	Nome com links e HTML enganoso em e-mail enviado pelo domínio legítimo.
Pré-condições	Ter conta e convidar alguém.
Impacto	Phishing.
Correção	Escapar o valor ou usar React Email.

INFORMATIVA SEC-015 Prompt injection possível, sem sink de impacto

Status: NOVO · **Prioridade:** P3 · **Confiança:** CONFIRMADO · **OWASP:** A05:2025 · **CWE-1427** · **TTP:** LLM / Prompt Injection

Arquivo	`app/api/ai/summarize/route.ts:12`
Evidência	`messages: [{ role: 'user', content: text }]`
Source	Texto da tarefa
Sink	Resposta do modelo, exibida como texto puro (sem tools)
Exploração	O texto pode manipular o resumo, mas o modelo não tem ferramentas e a saída é escapada pelo React.
Pré-condições	N/A
Impacto	Nenhum impacto de segurança hoje. Reavaliar se forem adicionadas tools.
Correção	Manter a saída como texto puro; se adicionar tools, aplicar a autorização do usuário final em cada uma.

Não confirmados

Itens investigados sem evidência suficiente. Não contam como achados.

Item	O que falta para confirmar
Policies do bucket 'avatars' no Supabase Storage	Criadas pelo painel, não estão nas migrations. Exportar as policies ou verificar no painel.
HTTP Request Smuggling	A Vercel é o único proxy; nenhuma condição de parsing divergente no código. Exigiria teste dinâmico.
Revogação da chave antiga do Stripe (B-06)	Informada pela equipe; confirmar no painel do Stripe.

Recomendações priorizadas

Prioridade	Ação
P1	Reescrever .github/workflows/preview.yml sem pull_request_target com checkout do PR; rotacionar VERCEL_TOKEN e a service role key por precaução (SEC-007).
P1	Verificar assinatura com stripe.webhooks.constructEvent em app/api/webhooks/stripe/route.ts (SEC-003).
P1	Corrigir os persistentes da básica: requireAdmin() nas rotas admin e policy de tasks por org_id (SEC-011, SEC-012).
P1	Bloquear IPs privados e metadata no teste de integração (SEC-001).
P2	Tornar o resgate de cupom atômico com UPDATE condicional (SEC-002).
P2	Exigir sessão, limitar tamanho e criar cota por organização em /api/ai/summarize (SEC-006).
P2	Allowlist de CORS e resposta neutra + rate limit no reset de senha (SEC-005, SEC-004).
P3	Fail-closed em limits.ts, audit log admin, atualizar Next.js, remover default de JWT_SECRET, escapar e-mail (SEC-008, 009, 010, 013, 014).

Issues para o GitHub

Texto pronto para copiar e colar. Nenhuma issue foi aberta automaticamente. Em repositório público, prefira um GitHub Security Advisory privado.

```
--- ISSUE 1 ---

# [Segurança] Workflow de preview expõe secrets a PRs de forks

Labels: security, crítica
Achados: SEC-007

## Descrição
preview.yml usa pull_request_target e faz checkout do código do PR, rodando npm ci com VERCEL_TOKEN e
a service role key no ambiente.

## Evidência
.github/workflows/preview.yml:3-24

## Impacto
Qualquer pessoa pode roubar os tokens de produção abrindo um PR.

## Correção sugerida
Usar on: pull_request sem secrets para build; deploy de preview apenas em workflow separado, acionado
por label aplicada por mantenedor. Definir permissions: read-all e pinar actions por SHA.

## Critérios de aceite
- [ ] Nenhum workflow com pull_request_target faz checkout do head do PR
- [ ] VERCEL_TOKEN e service role key rotacionados
- [ ] Actions pinadas por SHA

--- FIM ISSUE 1 ---
```

```
--- ISSUE 2 ---

# [Segurança] Webhook do Stripe sem verificação de assinatura

Labels: security, alta
Achados: SEC-003

## Descrição
O endpoint aceita qualquer JSON como evento do Stripe e ativa planos pagos.

## Evidência
app/api/webhooks/stripe/route.ts:9-21

## Impacto
Ativação gratuita do plano Pro.

## Correção sugerida
Ler o corpo bruto e validar com stripe.webhooks.constructEvent.

## Critérios de aceite
- [ ] Requisição sem assinatura válida retorna 400
- [ ] Teste com assinatura inválida
- [ ] Idempotência por event.id

--- FIM ISSUE 2 ---
```

```
--- ISSUE 3 ---

# [Segurança] Autorização: rotas admin e policy de tasks (persistentes da auditoria básica)

Labels: security, alta
Achados: SEC-011, SEC-012

## Descrição
Já apontados na auditoria básica (B-03 e B-02) e ainda presentes.

## Evidência
app/api/admin/users/[id]/route.ts:8-20
supabase/migrations/20250402_tasks_policies.sql:8-10

## Impacto
Remoção de contas e leitura de tarefas de outras organizações.

## Correção sugerida
requireAdmin() em todas as rotas admin; policy de tasks filtrando por org_id.

## Critérios de aceite
- [ ] Usuário comum recebe 403 nas rotas admin
- [ ] Usuário da org A não lê tasks da org B

--- FIM ISSUE 3 ---
```

```
--- ISSUE 4 ---

# [Segurança] SSRF no teste de webhook de integração

Labels: security, alta
Achados: SEC-001

## Descrição
A rota faz fetch em uma URL informada pelo usuário e devolve a resposta.

## Evidência
app/api/integrations/test/route.ts:11-19

## Impacto
Acesso a serviços internos e metadata de cloud.

## Correção sugerida
Validar esquema, resolver DNS e bloquear faixas privadas, inclusive após redirects; não retornar o cor
po.

## Critérios de aceite
- [ ] http://169.254.169.254 e http://localhost são rejeitados
- [ ] Redirects para IP privado são rejeitados

--- FIM ISSUE 4 ---
```

```
--- ISSUE 5 ---

# [Segurança] Abuso de cobrança: cupom reutilizável e endpoint de IA sem limite

Labels: security, alta
Achados: SEC-002, SEC-006

## Descrição
O resgate de cupom não é atômico e /api/ai/summarize é público e sem cota.

## Evidência
lib/billing/coupons.ts:31-44
app/api/ai/summarize/route.ts:6-18

## Impacto
Créditos ilimitados e custo descontrolado na OpenAI.

## Correção sugerida
UPDATE condicional atômico no cupom; sessão, limite de tamanho e cota por organização na rota de IA.

## Critérios de aceite
- [ ] 20 resgates simultâneos geram 1 crédito
- [ ] Rota de IA retorna 401 sem sessão e 429 acima da cota

--- FIM ISSUE 5 ---
```

```
--- ISSUE 6 ---

# [Segurança] Endurecimento: CORS, reset de senha, fail-open, audit log e dependências

Labels: security, média
Achados: SEC-004, SEC-005, SEC-008, SEC-009, SEC-010, SEC-013, SEC-014

## Descrição
Conjunto de melhorias de risco médio e baixo.

## Evidência
middleware.ts:18-23 · app/api/auth/reset/route.ts:7-16 · lib/billing/limits.ts:22-30 · app/api/admin/
· package.json:18 · docker-compose.yml:22 · lib/email/invite.ts:14

## Impacto
Reduz a superfície de ataque e melhora a capacidade de investigação.

## Correção sugerida
Ver recomendações P2 e P3 do relatório.

## Critérios de aceite
- [ ] CORS com allowlist fixa
- [ ] Reset com resposta neutra e rate limit
- [ ] limits.ts fail-closed
- [ ] audit_logs nas rotas admin
- [ ] next >= 14.2.25
- [ ] Sem default de JWT_SECRET
- [ ] E-mail com escape

--- FIM ISSUE 6 ---
```